

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A MOCK INTERVIEW

Code of Conduct:

I SABEER KHAN / 192212101 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

M.Sabeer khan

Annexure A

MOCK INTERVIEW

1. Which would you prioritize in a secure network design: **performance or security**, and how would you balance both?
2. Can you explain the difference between **stateful and stateless firewalls**, and which one is more suitable for enterprise networks?
3. If an IDS generates too many false positives, how would you optimize its performance?
4. How would you design a **real-time intrusion detection system** for high-speed networks?
5. What are the key challenges in detecting **zero-day malware**, and how would you address them?
6. How would you differentiate between **signature-based and anomaly-based IDS**, and when would you use each?
7. If a network is under a **DDoS attack**, what immediate and long-term mitigation strategies would you apply?
8. How would you secure **remote access** to an enterprise network?
9. What are the limitations of **traditional antivirus software**, and how can modern solutions overcome them?
10. How would you design a **secure email filtering system** to prevent phishing and spam attacks?
11. If an attacker bypasses firewall rules, what additional layers of security would you implement?
12. How would you evaluate the effectiveness of **network segmentation** in preventing cyberattacks?
13. What role does **encryption** play in preventing malware attacks, if any?
14. How would you secure a **cloud-based network infrastructure**?
15. What is the importance of **log analysis and monitoring** in network security?
16. How would you respond to a **security breach in a corporate network**?
17. What are the advantages and limitations of **next-generation firewalls (NGFW)**?
18. How would you integrate **IDS/IPS with SIEM systems** for better threat detection?
19. What are the best practices for **patch management and vulnerability assessment**?
20. How would you design a **future-proof network security architecture** considering emerging threats?

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive attitude, and professional	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism

		behavior throughout			
--	--	------------------------	--	--	--

1. Performance or Security in Secure Network Design

In a secure network, **security should be given higher priority**, but performance should not be ignored. A highly secure network that is extremely slow can affect productivity, while a very fast network with weak security can expose sensitive information to attackers. Therefore, the best approach is to balance both using a **risk-based security design**.

Security can be improved by using firewalls, IDS/IPS, encryption, authentication, access control, network segmentation, and regular monitoring. At the same time, performance can be maintained by using efficient security devices, load balancing, optimized firewall rules, and hardware acceleration. Security controls should be placed according to the importance of the data and systems. Regular performance testing and security assessments can help maintain the right balance.

2. Stateful and Stateless Firewalls

A **stateless firewall** examines each network packet independently based mainly on information such as source IP, destination IP, port number, and protocol. It does not remember previous packets or connections. It is simple and fast, but it provides limited protection against complex attacks.

A **stateful firewall** maintains information about active network connections and understands the state of communication. It can determine whether a packet belongs to an existing legitimate connection. Stateful firewalls provide better security and are more suitable for most **enterprise networks**.

In enterprise environments, stateful firewalls are generally preferred because they provide stronger control over traffic while still offering good performance. Modern enterprises may also use **next-generation firewalls (NGFWs)** that combine stateful inspection with application control, intrusion prevention, and threat intelligence.

3. Reducing False Positives in IDS

An Intrusion Detection System (IDS) may sometimes identify legitimate activities as attacks. These are called **false positives**. Too many false positives can overload security administrators and may cause real threats to be missed.

To optimize an IDS, I would first analyze the alerts and identify frequently occurring legitimate activities. The detection rules can then be tuned to reduce unnecessary alerts. Thresholds can be adjusted based on the organization's normal traffic patterns. The IDS should also be updated with current threat intelligence and signatures.

Using **anomaly detection, machine learning, whitelisting, alert correlation, and severity-based prioritization** can further improve accuracy. Regular monitoring and periodic rule reviews are important because network behavior changes over time.

4. Real-Time IDS for High-Speed Networks

A real-time intrusion detection system for a high-speed network should be designed to process large amounts of traffic with minimum delay. The system should use high-performance sensors positioned at important network points. Traffic can be captured using efficient packet-processing technologies.

The IDS should combine **signature-based detection and anomaly-based detection**. Known attacks can be identified quickly using signatures, while unusual behavior can be detected through anomaly analysis. A distributed architecture can be used so that multiple sensors analyze traffic simultaneously.

Machine learning can help classify suspicious behavior, while a central monitoring system can correlate alerts. The system should also use filtering and traffic sampling where appropriate to reduce processing overhead. High availability, scalable processing, and low latency are essential for real-time detection.

5. Challenges in Detecting Zero-Day Malware

Zero-day malware is difficult to detect because it exploits vulnerabilities or uses attack techniques that are not yet known to security vendors. Traditional signature-based antivirus and IDS systems may not have signatures for such threats.

To address zero-day attacks, organizations should use **behavior-based detection, sandboxing, endpoint detection and response (EDR), machine learning, threat intelligence, and application control**. Suspicious files can be executed in isolated sandbox environments to observe their behavior before allowing them into the main network.

Regular patching is also important because attackers often exploit unpatched vulnerabilities. Network segmentation, least-privilege access, continuous monitoring, and rapid incident response can reduce the impact even when a zero-day attack succeeds.

6. Signature-Based and Anomaly-Based IDS

Signature-based IDS detects attacks by comparing network activity with a database of known attack patterns or signatures. It is highly effective for detecting known threats and generally produces reliable results. However, it may fail to detect new or modified attacks.

Anomaly-based IDS establishes a baseline of normal network behavior and identifies significant deviations from that baseline. It can detect previously unknown attacks and zero-day threats, but unusual legitimate activities may sometimes generate false positives.

In practice, both methods should be used together. Signature-based detection is useful for known malware and attack patterns, while anomaly-based detection is useful for identifying new or unusual threats. A hybrid IDS provides broader protection.

7. DDoS Attack Mitigation

During a **Distributed Denial-of-Service (DDoS)** attack, the immediate objective is to keep critical services available. Traffic should be monitored to identify abnormal patterns. Malicious traffic can be blocked using firewall and filtering rules, rate limiting, access control lists, and traffic scrubbing services.

For large attacks, organizations can use **DDoS protection services, content delivery networks (CDNs), upstream filtering, and traffic rerouting**. Critical services should be prioritized so that essential operations remain available.

For long-term protection, organizations should develop a DDoS response plan, increase network capacity where necessary, deploy automated detection, and regularly test their defenses. Redundant infrastructure and geographically distributed services can also improve availability.

8. Securing Remote Access

Remote access should be protected using strong authentication and encrypted communication. **Virtual Private Networks (VPNs)** can provide encrypted connections between remote users and enterprise networks. Multi-factor authentication (MFA) should be enabled so that a stolen password alone is not enough to gain access.

Access should follow the **principle of least privilege**, allowing users to access only the resources required for their jobs. Devices connecting remotely should also be checked for security status, including operating-system updates and endpoint protection.

Modern organizations can use Zero Trust principles, where every access request is continuously verified instead of automatically trusting users or devices inside the network.

9. Limitations of Traditional Antivirus

Traditional antivirus software mainly depends on known malware signatures. Therefore, it may not detect new, modified, or highly sophisticated malware. Attackers can also use techniques such as fileless malware, obfuscation, and polymorphic code to avoid traditional detection.

Modern security solutions overcome these limitations using **behavior analysis, machine learning, cloud-based threat intelligence, sandboxing, EDR, and real-time monitoring**. Instead of only asking whether a file matches a known signature, modern systems analyze what the program is doing.

Combining endpoint protection with network monitoring, application control, vulnerability management, and user awareness provides stronger protection against modern malware.

10. Secure Email Filtering System

A secure email filtering system should inspect incoming and outgoing messages before they reach users. It should identify spam, malicious attachments, suspicious links, and phishing attempts.

The system can use **spam filtering, malware scanning, URL reputation checking, attachment sandboxing, and sender authentication mechanisms** such as SPF, DKIM, and DMARC. Messages from suspicious sources can be quarantined for further inspection.

Machine learning can also identify unusual email behavior, such as suspicious language, abnormal sending patterns, or impersonation attempts. Users should receive warnings

when they interact with potentially dangerous links. Regular security awareness training is also necessary because technology alone cannot prevent every phishing attack.

11. Security Layers After Firewall Bypass

A firewall is only one layer of network defense. If an attacker bypasses firewall rules, additional security controls should limit their ability to move through the network.

Important layers include **IDS/IPS, endpoint protection, network segmentation, MFA, access control, encryption, SIEM monitoring, and Zero Trust security**. Network segmentation can prevent an attacker from easily moving from one compromised system to critical servers.

Endpoint detection can identify suspicious processes, while SIEM systems can correlate events from different devices. Least-privilege access ensures that even compromised accounts have limited permissions. A layered security approach is therefore more effective than depending on a single firewall.

12. Evaluating Network Segmentation

Network segmentation divides a large network into smaller security zones. Examples include separate networks for employees, servers, guests, databases, and critical systems. The effectiveness of segmentation can be evaluated by testing whether an attacker who compromises one segment can reach another segment.

Security teams can conduct penetration testing and review firewall and access-control rules between segments. They can measure the number of systems accessible from a compromised device and verify whether sensitive resources are isolated.

Useful measures include reduced lateral movement, fewer unauthorized connections, faster detection, and limited attack impact. Proper segmentation should ensure that compromising one network area does not automatically provide access to the entire organization.

13. Role of Encryption Against Malware

Encryption does not directly prevent malware from infecting a system. However, it plays an important role in protecting **data confidentiality and integrity**. Encryption makes stolen information difficult for unauthorized persons to understand.

Encryption can protect data while it is being transmitted through networks and while it is stored. Technologies such as TLS and encrypted storage reduce the risk of attackers intercepting sensitive information.

However, encryption can also create security challenges because attackers may use encrypted communication to hide malicious traffic. Therefore, organizations need appropriate monitoring and security controls while maintaining privacy and legitimate encryption requirements.

14. Securing Cloud-Based Network Infrastructure

Cloud infrastructure should follow a **defense-in-depth and Zero Trust approach**. Strong identity and access management is essential because cloud resources are accessed through accounts and APIs. MFA and least-privilege permissions should be implemented for users and services.

Cloud networks should use security groups, network access controls, segmentation, encryption, secure APIs, and continuous monitoring. Sensitive data should be encrypted both at rest and in transit.

Regular vulnerability assessments, configuration reviews, logging, backup, and incident-response procedures should also be implemented. Organizations must clearly understand the **shared responsibility model**, where security responsibilities are divided between the cloud provider and the customer.

15. Importance of Log Analysis and Monitoring

Logs provide records of activities performed on computers, servers, applications, firewalls, and network devices. Log analysis helps security teams identify suspicious activities and investigate security incidents.

For example, repeated failed login attempts may indicate a brute-force attack, while unusual data transfers may indicate data theft. Centralized collection of logs makes it easier to correlate events from different systems.

A **Security Information and Event Management (SIEM)** system can collect, analyze, and correlate security events and generate alerts. Continuous monitoring helps organizations detect attacks earlier, investigate incidents, meet compliance requirements, and improve overall security visibility.

16. Responding to a Corporate Security Breach

When a security breach occurs, the first step is to **identify and confirm the incident**. The affected systems should then be isolated to prevent further damage. Security teams should preserve logs and other evidence for investigation.

Next, the organization should determine the attack method, affected systems, compromised accounts, and possible data loss. Malware should be removed and vulnerabilities should be fixed. Compromised passwords and credentials should be reset.

After recovery, systems should be carefully restored and continuously monitored. Finally, a post-incident analysis should be performed to understand what happened and how similar incidents can be prevented. An incident-response plan helps organizations respond quickly and systematically.

17. Advantages and Limitations of NGFW

A **Next-Generation Firewall (NGFW)** provides more advanced security than a traditional firewall. It can inspect applications, identify users, detect malicious traffic, and integrate intrusion prevention and threat intelligence.

Its advantages include application-level control, better visibility, integrated security features, and improved threat detection. It can also control traffic based on applications and users rather than only IP addresses and ports.

However, NGFWs can be more expensive and complex to configure. Deep packet inspection and advanced security features may also affect network performance. Skilled administrators are required to maintain them properly. Despite these limitations, NGFWs are highly useful in modern enterprise networks.

18. Integrating IDS/IPS with SIEM

IDS/IPS devices detect suspicious or malicious network activity, while a **SIEM** collects security events from multiple sources. Integrating them provides a broader view of security incidents.

IDS/IPS alerts can be forwarded to the SIEM along with firewall, server, endpoint, authentication, and application logs. The SIEM can correlate these events to identify attack patterns. For example, a failed login followed by suspicious network traffic and an endpoint alert may indicate a compromised account.

Security teams can use SIEM dashboards and automated alerts to prioritize serious incidents. Integration can also support automated response actions and improve incident investigation.

19. Patch Management and Vulnerability Assessment

Effective patch management begins with maintaining an accurate inventory of hardware, software, applications, and operating systems. Vulnerability scanners can identify known weaknesses in these systems.

Vulnerabilities should be prioritized based on **severity, exploitability, asset importance, and business impact**. Critical security patches should be tested and deployed quickly. Updates should first be tested in a controlled environment to reduce the possibility of disrupting important services.

Organizations should maintain a regular patch schedule, verify successful installation, and document all changes. Vulnerability assessments should be performed regularly, followed by remediation and re-testing to confirm that weaknesses have been resolved.

20. Future-Proof Network Security Architecture

A future-proof security architecture should be designed to handle continuously changing threats. It should not depend on a single security technology. Instead, organizations should

use **defense in depth**, Zero Trust principles, strong identity management, segmentation, encryption, endpoint security, IDS/IPS, SIEM, and automated threat detection.

Artificial intelligence and machine learning can help identify unusual behavior and improve threat detection. Cloud and hybrid environments should be protected through continuous monitoring and secure configurations. Security systems should also be regularly updated as new threats and vulnerabilities appear.

Organizations should conduct security assessments, penetration testing, employee awareness training, vulnerability management, and incident-response exercises. The architecture should be scalable so that new technologies can be integrated without redesigning the entire network.